

Procedimiento de respuesta ante baneo por Fail2ban (SSH)

1. Objetivo

Definir los pasos necesarios para identificar, analizar y actuar ante un bloqueo de acceso provocado por Fail2ban en el servicio SSH, garantizando una respuesta segura y controlada.

2. Alcance

Este procedimiento aplica al servidor Ubuntu y al servicio SSH protegido mediante Fail2ban.

3. Comprobación del estado de Fail2ban

Para verificar que el servicio está activo:

- `Sudo systemctl status fail2ban`

Para comprobar el estado específico de del servicio SSH:

- `sudo fail2ban-client status sshd`

Esto mostrará:

- Numero de IPs bloqueadas
- Lista de IPs baneadas
- Numero de intentos fallidos

4. Identificación de IP bloqueada

Dentro del jail sshd, se puede observar:

- `Banned IP list:`

Aquí se listan las direcciones IP bloqueadas.

Ejemplo:

- `192.168.100.11`

5. Análisis del motivo del baneo

Fail2ban bloquea IPs tras múltiples intentos fallidos de autenticación.

Para revisar los intentos fallidos:

- `Sudo tail -f /var/log/auth.log`

Se puede identificar:

- Intentos de acceso incorrectos
- Usuarios utilizados
- Frecuencia de los intentos

6. Medidas para evitar futuros bloqueos

Para reducir la posibilidad de baneo:

- Usar contraseñas seguras
- Evitar múltiples intentos fallidos consecutivos
- Verificar usuario antes de autenticarse
- Considerar uso de claves SSH (mejora avanzada)

7. Desbloqueo controlado de una IP (opcional)

Solo realizar si se confirma que no es un ataque.

Para eliminar el bloqueo de una IP:

- `Sudo fail2ban-client set sshd unbanip 192.168.100.X`

8. Validación

Tras el desbloqueo:

1. Intentar conexión SSH nuevamente
2. Verificar acceso correcto
3. Confirmar que no se generan nuevos bloqueos

9. Buenas practicas

- No desbloquear IP sin verificar su origen
- Monitorizar logs regularmente
- Mantener Fail2ban activo en todo momento
- Revisar configuración de tiempos de baneo si es necesario

Este procedimiento permite gestionar de forma eficiente los bloqueos automáticos, diferenciando entre actividad maliciosa y errores de autenticación legítimos.